

Unit 1

1. Define InfoSec. What are the specialized areas and components of Information Security?
2. Describe CNSS security model. What are the three dimensions?
3. Write a note on CIA triad.
4. What are the types of espionage?
5. How technical software failure can create threat to information security.
6. Difference between Dos and DDoS attack.
7. Which human errors can create threat to information security?
8. How information extortion and sabotage create threat to information security?
9. Which roles manager has to play within organizations?
10. What are the types of leaders?
11. What are the characteristics of management?
12. Write problem solving steps.
13. What are the 7 P's of information security management?
14. Define the InfoSec processes of identification, authentication, authorization and accountability.
15. What are the types of password attacks? What can a system administrator do to protect against them?
16. What are the various types of malware? How do worms differ from viruses?

Unit 2

1. What are the three general categories of unethical and illegal behavior?
2. Difference between law and ethics
3. Write a note on ethics
4. What are the various methods for preventing unethical and illegal behavior?
5. List professional organizations and write codes of conduct of any 2 organizations.
6. What are the types of law?
7. Difference between civil law and criminal law.
8. List U.S. laws and explain any 4 of them.
9. What is the importance of international laws and legal bodies?
10. Write a note on digital forensic.
11. What is evidentiary material?
12. Write a note on ethics.
13. What are the various methods for preventing unethical and illegal behavior?
14. In what ways SANS is involved in professional certification for InfoSec professional?
15. Explain general computer crime law.
16. Write a note on HIPAA.
17. Write a note on privacy laws.

Unit 3

1. What is planning?
2. Write a note on mission statement, vision statement and value statement.
3. What are the three common levels of planning? Explain each of them.
4. Describe top-down strategic planning. How does it differ from bottom-up strategic planning? Which is more effective in implementing security in large, diverse organization?

5. What is InfoSec governance? Mention benefits of InfoSec governance.
6. What are the basic outcomes that should be achieved through Infosec governance?
7. What are the benefits of Infosec governance?
8. Explain IDEAL model designed by CGTF framework.
9. Write a note on CGTF framework.
10. Explain supporting documents included in GES.
11. Write a note on ISO/IEC 27014:2013.
12. What is security convergence?
13. Write a note on planning for InfoSec implementation.
14. What is objective of SecSDLC? What are its major steps? What are major objectives of each step?
15. Describe approaches to security implementation.
16. Why is maintenance needed for information security management systems?
17. What is managerial control, operational control and technical control?

Unit 4

1. What is information security policy?
2. Why InfoSec policy is important?
3. Describe Bull's eye model? What does it say about policy in the InfoSec Program?
4. How policy, standards, practices, procedures & guidelines differ from each other?
5. What is the purpose of EISP?
6. List & describe four elements that should be present in the EISP.
7. What is the purpose of ISSP?
8. Explain elements of ISSP.
9. What is the purpose of SysSP?
10. List & describe the two general groups of material included in most SysSP documents.
11. List & describe the three types of InfoSec policy as described by NIST SP 800-14.
12. List & describe three common ways in which ISSP documents are created and/or managed?
13. Describe the approach used to create effective & legally defensible policy.
14. Write a note on policy development & implementation using SDLC.
15. What is attained by policy development team or committee during investigation phase?
16. Which resources can be referred while designing a good policy document?
17. How software tools support policy administration?

Unit 5

1. What is risk management?
2. List and describe the key areas of concern for risk management.
3. Why is identification of risks, through a listing of assets and their vulnerabilities, so important to the risk management process?
4. According to Sun Tzu, what two things must be achieved to secure information assets successfully?
5. Write a note on risk management framework.
6. How risk management framework and process are inter-related?
7. Write a note on RM policy.
8. What is organizations risk tolerance and risk appetite?
9. How RM process is prepared by establishing the context?
10. How information assets are identified?
11. Which questions are considered while assessing the value of information asset?
12. Explain risk evaluation.
13. What is the difference between an asset's ability to generate revenue and its ability to generate profit?

14. How many categories might a typical data classification scheme include? Why?
15. How many threat categories are listed in this chapter? Which is noted as being the most frequently encountered, and why?
16. What are vulnerabilities?
17. Describe the TVA worksheet. What is it used for?

Unit 6

1. What is risk treatment? What is competitive advantage and disadvantage? Why it emerged as a factor?
2. Describe mitigation risk treatment strategy.
3. List five risk treatment strategies. Describe anyone strategy.
4. Describe transference risk treatment strategy.
5. Write a note on cost-benefit analysis.
6. How asset valuation is done using quantitative approach?
7. What is single loss expectancy? What is annualized loss expectancy?
8. What is total cost of ownership?
9. What are methods of establishing feasibility?
10. How does Microsoft define risk management? What faces are used in its approach?
11. Write a note on – a) qualitative and hybrid asset valuation measures
b) Delphi technique
12. Write a note on OCTAVE method.
13. Elaborate FAIR framework.
14. Explain ISO standards for InfoSec risk management.
15. What is NIST Risk management framework?
16. How selecting best risk management model is important?